M 304: MobSF Static Analysis (25 pts extra)

What You Need for This Project

- A Linux virtual machine

Purpose

To practice using Mobile Security Framework (MobSF), an automated, all-in-one mobile application (Android/iOS/Windows) pen-testing, malware analysis and security assessment framework capable of performing static and dynamic analysis.

Finding your Linux Server's IP Address

On Linux, execute this command:

```
ip a
```

Make a note of your Linux server's IP address. You'll need it later.

Installing Docker

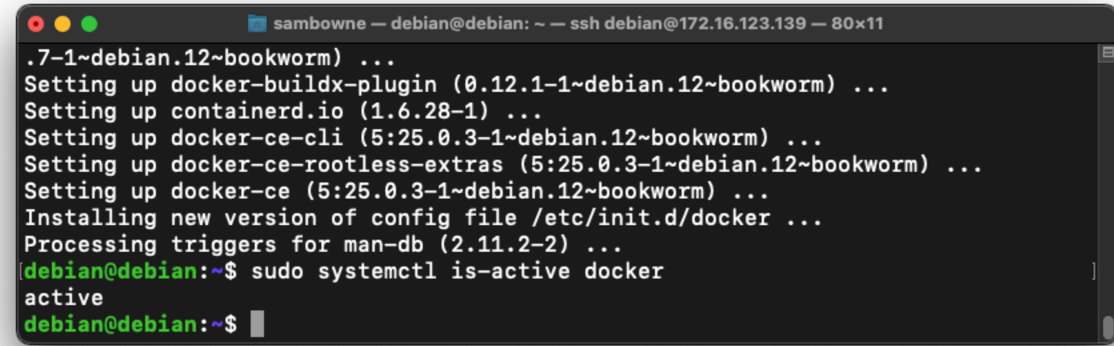
MobSF runs as a Docker container, which is like a smaller, faster virtual machine.

To run Docker containers, you must first install docker.

On Linux, execute these commands, one at a time. Notice that some of these commands continue onto a second line.

```
sudo apt update

sudo apt install apt-transport-https ca-certificates curl gnupg git

curl -fsSL https://download.docker.com/linux/debian/gpg \
  | sudo gpg --dearmor -o /usr/share/keyrings/docker.gpg

echo "deb [arch=$(dpkg --print-architecture) signed-by=/usr/share/keyrings/docker.gpg] https://download.docker.com/linux/debian bookworm stable" \
  | sudo tee /etc/apt/sources.list.d/docker.list > /dev/null

sudo apt update

sudo apt install docker-ce docker-ce-cli containerd.io docker-buildx-plugin

sudo systemctl is-active docker
```

Docker is active, as shown below.



Installing MobSF

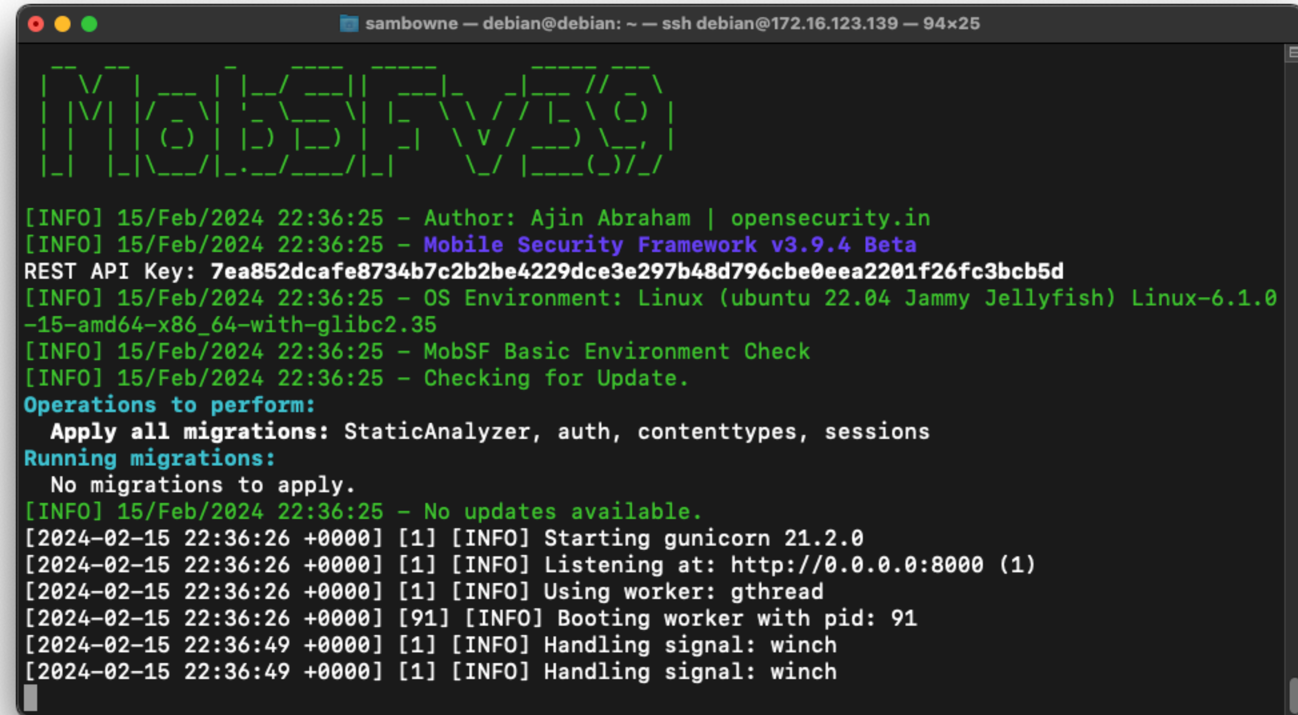
On Linux, in a Terminal, execute these commands, one at a time.

The pull command downloads a lot of data, and may take a long time if your network is slow.

```
sudo docker pull opensecurity/mobile-security-framework-mobsf:latest
```

```
sudo docker run -it --rm -p 8000:8000 opensecurity/mobile-security-framework-mobsf:latest
```

MobSF starts listening on port 8000, as shown below.



Viewing the MobSF Web Page

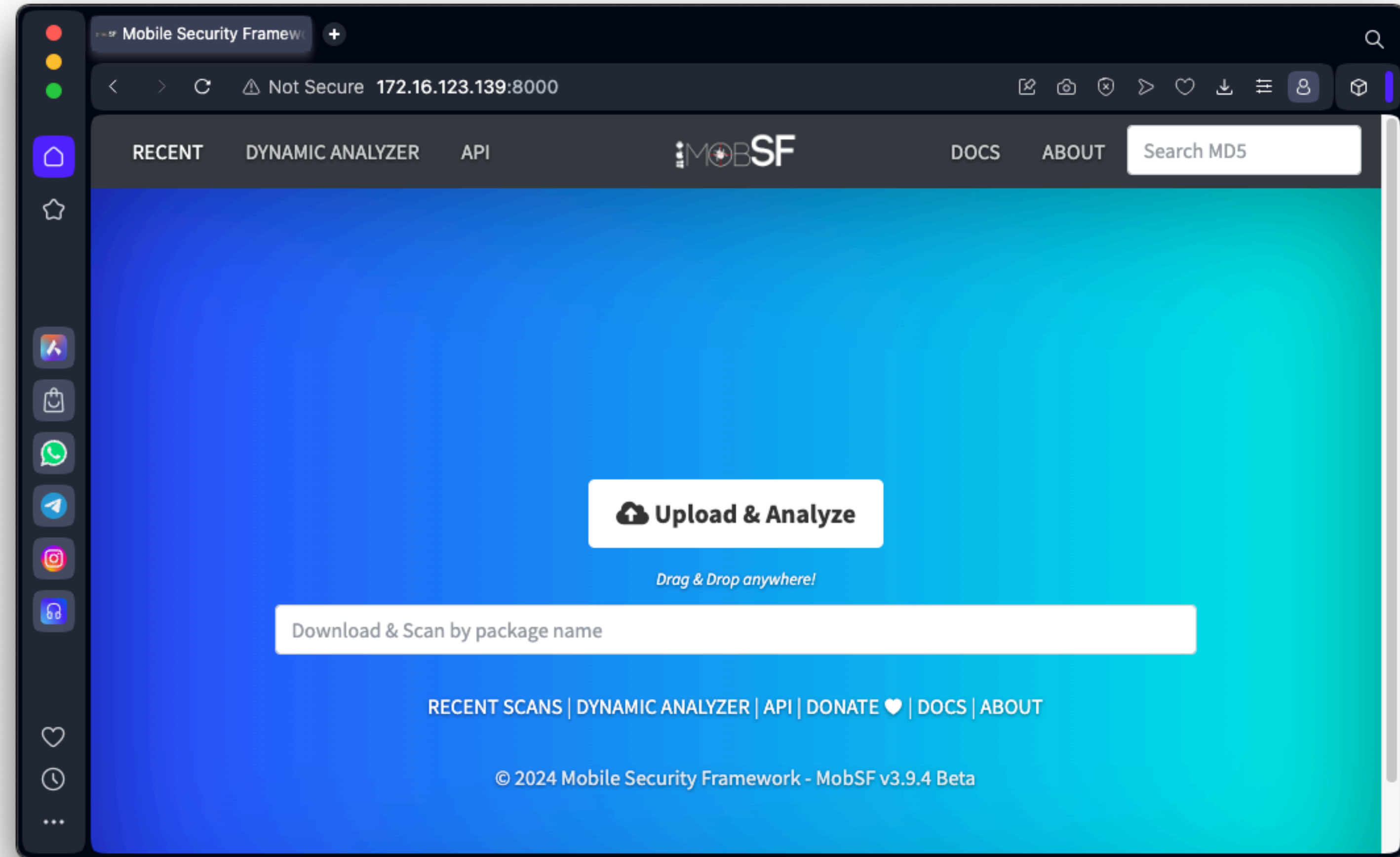
In a Web browser, open this URL, replacing the IP address with the correct IP address of your Linux server:

```
http://172.16.123.139:8000
```

You see the MobSF Web page.

Log in with a username and password of **mobsf**

You see the "Upload & Analyze" page, as shown below.



Analyzing a Vulnerable App

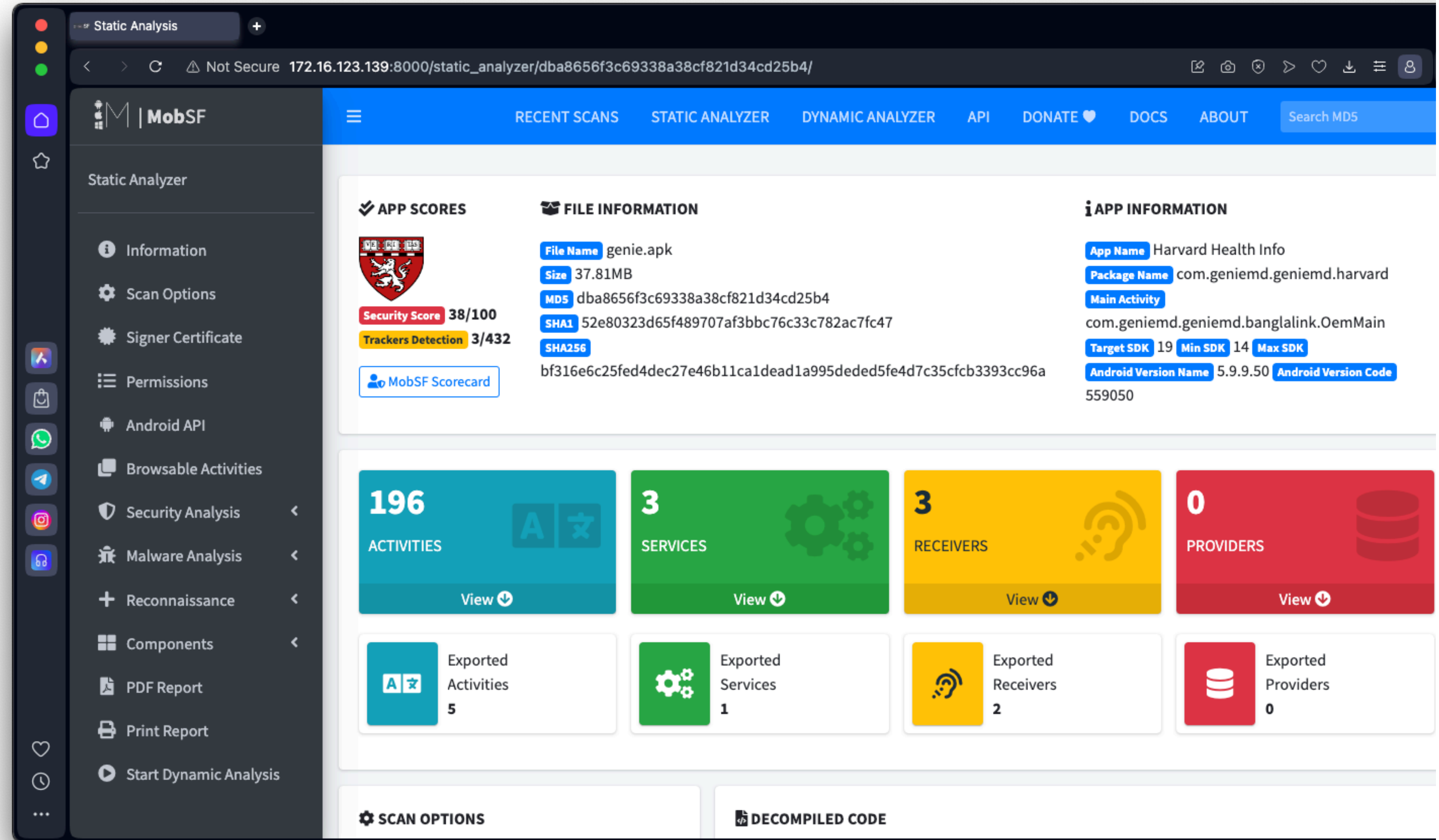
Download this APK file:

[genie.apk]()

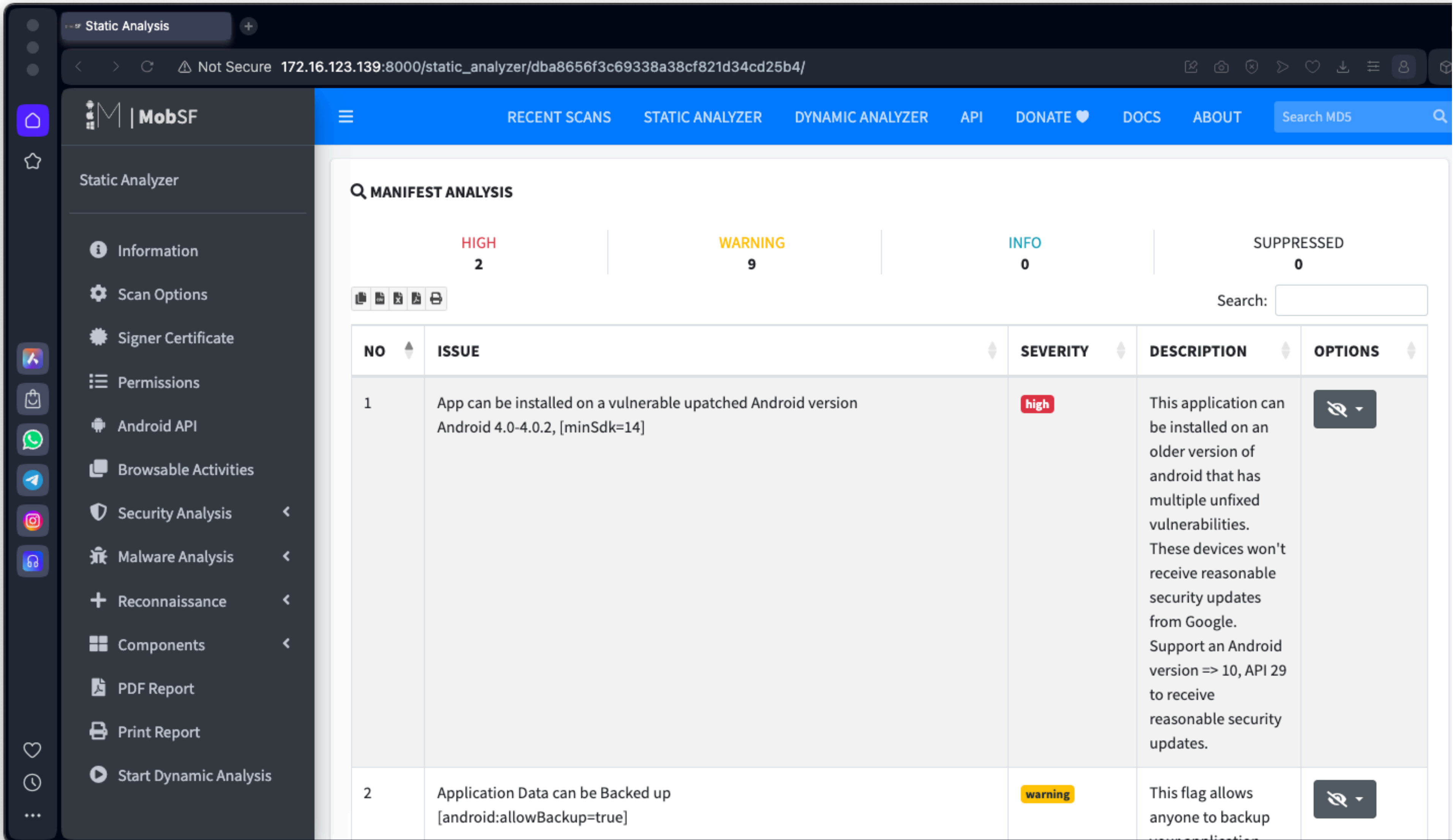
Drag and drop the **genie.apk** file onto the MobSF Web page.

Wait while the MobSF analyzes the app.

When it finishes, you see a pretty display of the results, as shown below.

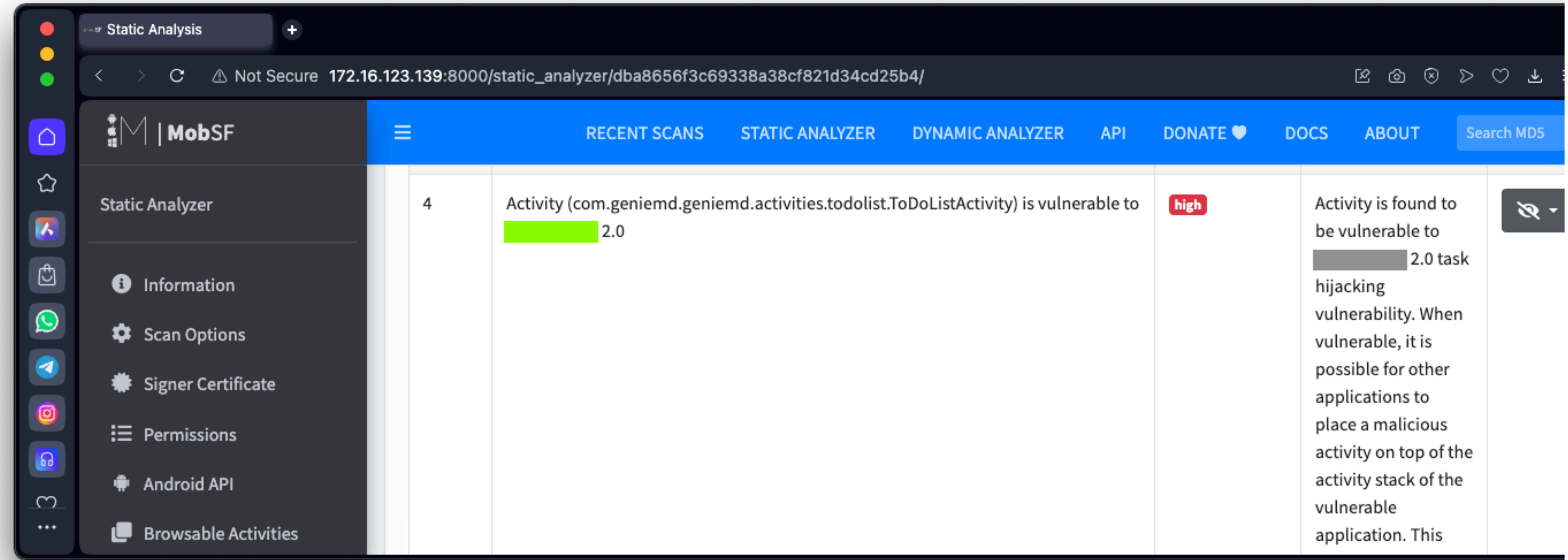


Scroll down to the MANIFEST ANALYSIS section as shown below.



M 304.1: Hijacking Vulnerability (10 pts)

In the the MANIFEST ANALYSIS section, find the text covered by a green box in the image below. That's the flag.



M 304.2: MANIFEST ANALYSIS (5 pts)

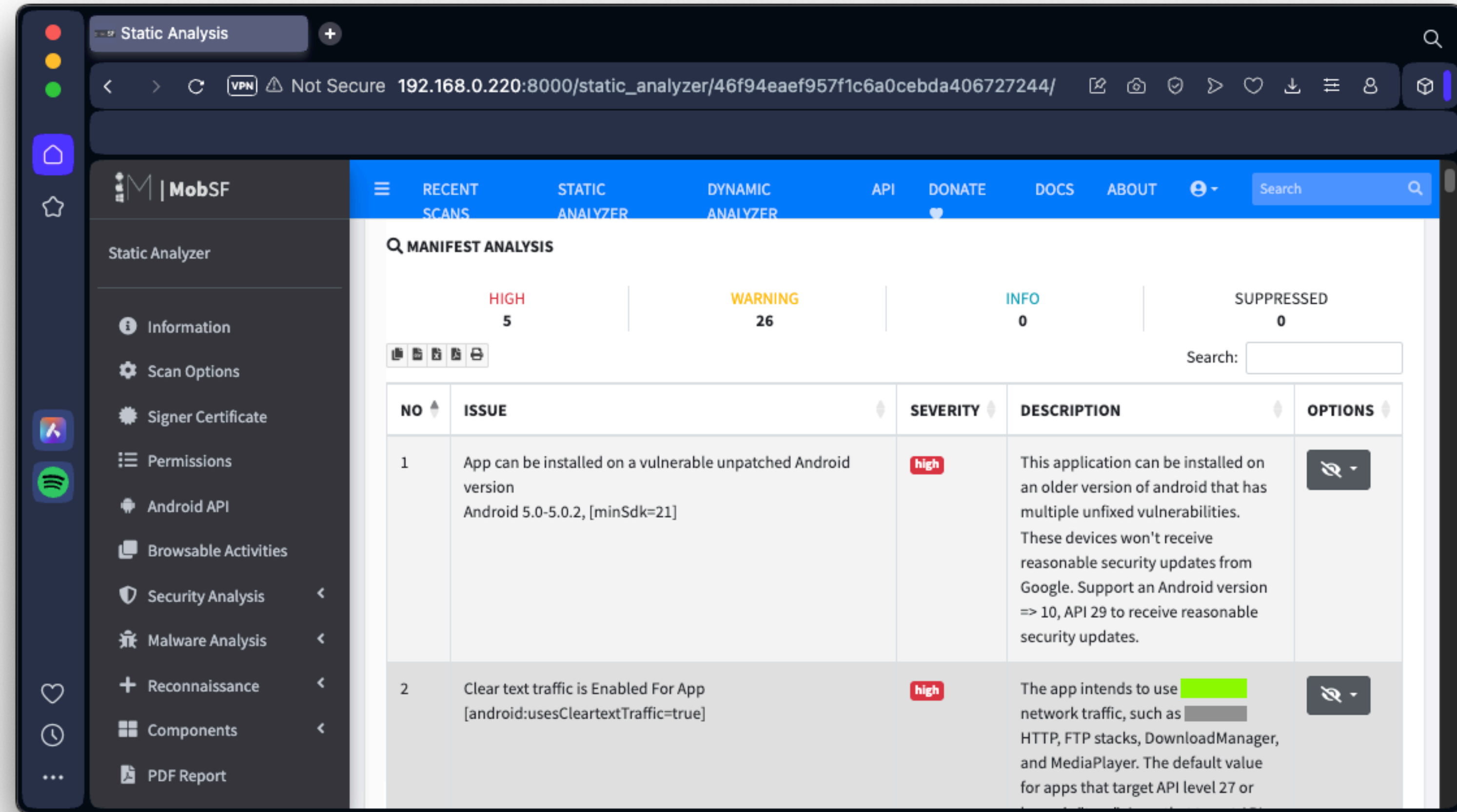
At the top left, click the **MobSF** logo.

Analyze this app, which the [Chinese government](#) uses to scan phones of citizens:

[National_Anti_Fraud_Center.apk](#)

The app is larger than the "genie" app, so the analysis will take longer.

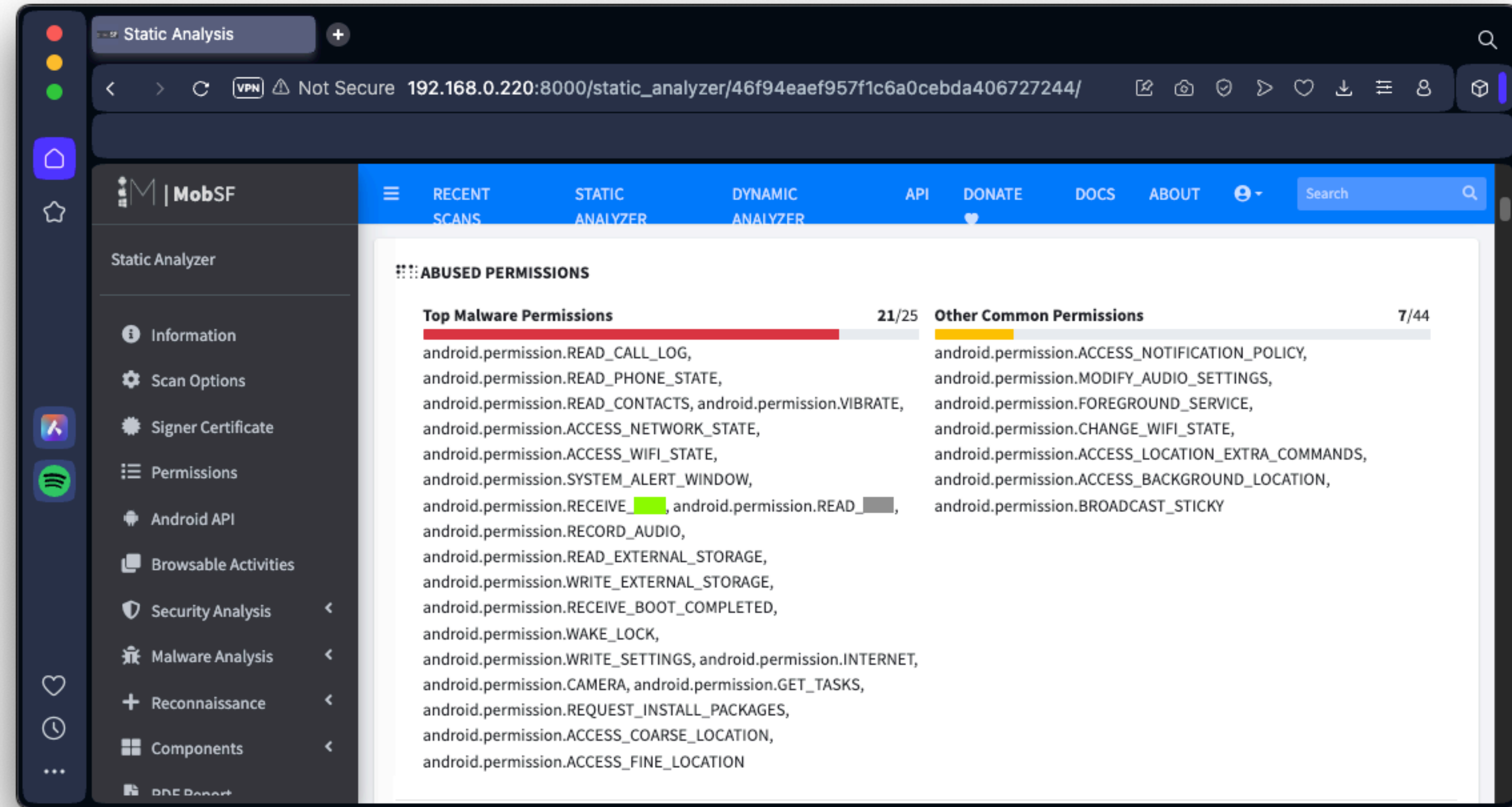
In the the MANIFEST ANALYSIS section, find the text covered by a green box in the image below. That's the flag.



M 304.3: ABUSED PERMISSIONS (5 pts)

For the National_Anti_Fraud_Center.apk, examine the ABUSED PERMISSIONS.

Find the text covered by a green box in the image below. That's the flag.



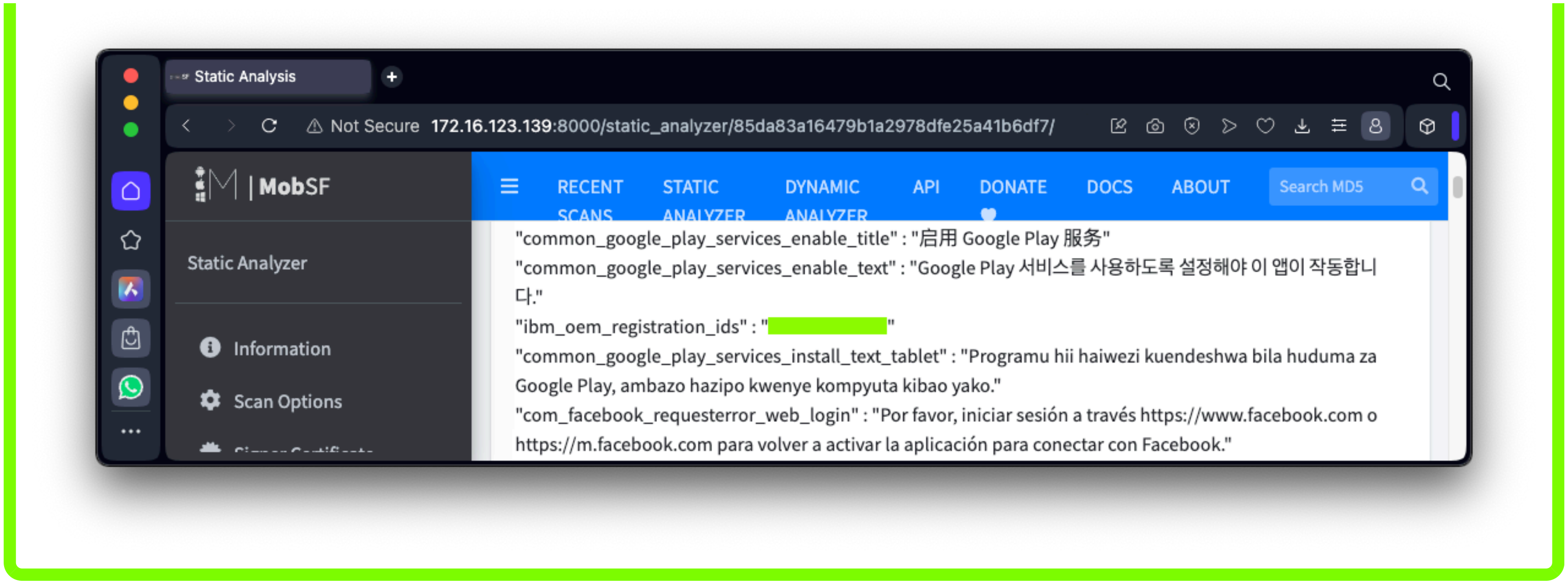
M 304.4: Registration Code (5 pts)

Analyze this app:

https://www.bowneconsultingcontent.com/pub/Attack/proj/A31.2.apk

Near the bottom of the page, in the Strings section, expand the container to see all the strings.

find the registration code, covered by a green box in the image below. That's the flag.



References

[Mobile Security Framework (MobSF)]
[MobSF Documentation]
[Dynamic Analysis Not Supported in Docker]

Posted 2-15-24
Login section added 6-10-25
Images updated 11-5-25